



Federal Office
for Information Security

Deutschland
Digital•Sicher•BSI•

Vulnerability management with CSAF – why SBOM is not enough

Thomas Schmidt
Federal Office for Information Security (BSI)

Who am I?

Thomas Schmidt

Technical ICS Analyst @BSI
(usually not into standardization)

First day at work: analyze TRITON / TRISIS

Passion for

- ICS
- International Cooperation
- CVD
- Capacity building



Vulnerability management

- Know the vulnerability
 - Details
 - Impact
 - Risks
 - Exploitability
 - ...
- Know where the component is used
- Know how to remediate
 - What do I need to do?

Vulnerability management

- Know the vulnerability
 - Details
 - Impact
 - Risks
 - Exploitability
 - ...

CVE
- Know where the component is used

SBOM
- Know how to remediate
 - What do I need to do?

Security Advisory

Just knowing the component is included is not enough...

Just knowing the component is included is not enough...

... as you usually don't have them in your asset database

Just knowing the component is included is not enough...

...as it says nothing whether the vulnerability is exploitable in the product



TRANSFORMING THE VULNERABILITY MANAGEMENT LANDSCAPE

Original release date: November 10, 2022 | Last revised: November 14, 2022

By Eric Goldstein, Executive Assistant Director for Cybersecurity

In the current risk environment, organizations of all sizes are challenged to manage the number and complexity of new vulnerabilities. Organizations with mature vulnerability management programs seek more efficient ways to triage and prioritize efforts. Smaller organizations struggle with understanding where to start and how to allocate limited resources. Fortunately, there is a path toward more efficient, automated, prioritized vulnerability management. Working with our partners across government and the private sector, we are excited to outline three critical steps to advance the vulnerability management ecosystem:

- First, we must introduce greater automation into vulnerability management, including by expanding use of the Common Security Advisory Framework (CSAF)

1. Achieving Automation: Publish machine-readable security advisories based on the Common Security Advisory Framework (CSAF).

With these advances, described further below, we will make necessary progress in vulnerability management and reduce the window that our adversaries have to exploit American networks.

1. Achieving Automation: Publish machine-readable security advisories based on the Common Security Advisory Framework (CSAF).

When a new vulnerability is identified, software vendors jump into action: understanding impacts to products, identifying remediations, and communicating to end users. But as we know, the clock is ticking: adversaries are often turning vulnerabilities to exploits within hours of initial public reports.

Software vendors work constantly to understand if their products are impacted by a new vulnerability. To meet this timeframe, our community needs a standardized approach for vendors to disclose security vulnerabilities to end users in an accelerated and automated way.

The [CSAF](#), developed by the OASIS CSAF Technical Committee, is a standard for machine-readable security advisories. CSAF provides a standardized format for ingesting vulnerability advisory information and simplify triage and remediation processes for asset owners. By publishing security advisories using CSAF, vendors will dramatically reduce the time required for enterprises to understand organizational impact and drive timely remediation.

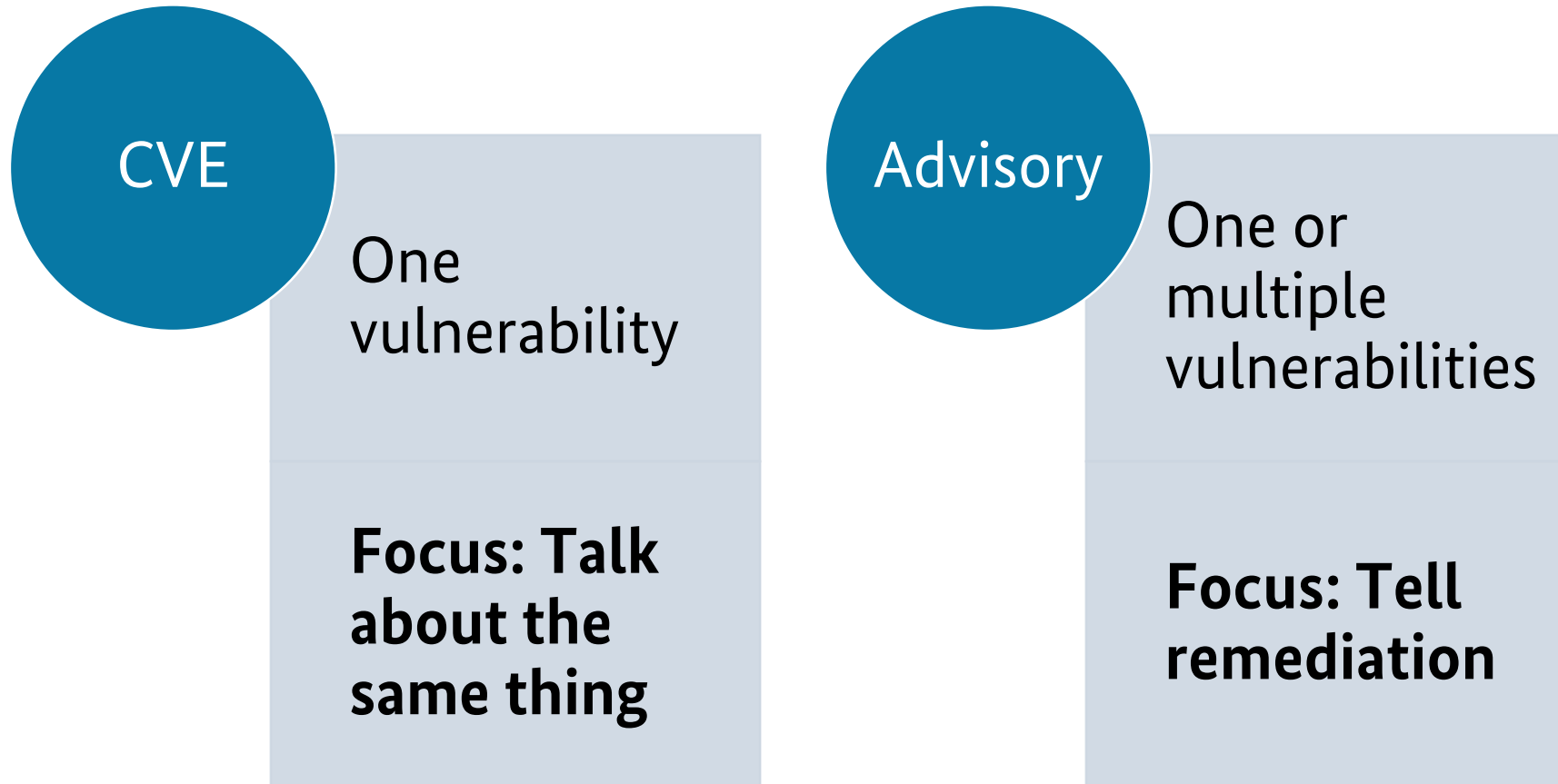
2. **Clarifying Impact: Use Vulnerability Exploitability eXchange (VEX) to communicate whether a product is affected by a vulnerability and enable prioritized vulnerability response**



Security Advisories

- Details about the vulnerabilities (including a CVE)
- **Products that are affected**
- Remediation
- Scores
- General guidance

CVE vs. Advisories



Security Advisories

- Details about the vulnerabilities (including a CVE)
- Products that are affected
- **Remediation**
- Scores
- General guidance

Security Advisories

- Details about the vulnerabilities (including a CVE)
- Products that are affected
- **Remediation**
 - *Hotfix*
 - *Update*
 - *Upgrade*
 - *Mitigating countermeasures*
 - ...
- Scores
- General guidance

} Patch

For each new vulnerability, decide



Patch
immediately



Patch next
downtime



Accept risk

How to decide?



Risk-based approach

Risk and cost scales depend on:

- Vulnerability
- Safety impact
- Usage of the product
- Existing countermeasures in the infrastructure
- Likelihood of broken patches / incompatibilities
- Attacks in the wild



Where do I get the information?



Security advisories!

 An official website of the United States government

[Here's how you know](#)

CYBERSECURITY & INFRASTRUCTURE

SECURITY AGENCY

CYBERSECURITY & INFRASTRUCTURE

SECURITY AGENCY

[Services](#)

[Report](#)

[Alerts and Tips](#)

[Resources](#)

[Industrial Control Systems](#)

ICS Advisory (ICSA-21-138-01)

 Print
 Tweet
 Send
 Share

All information products included in <https://us-cert.ssa.gov/ics> are provided "as is" for informational purposes only. The Department of Homeland Security (DHS) does not provide any warranties of any kind regarding any information contained within. DHS does not endorse any commercial product or service, referenced in this product or otherwise. Further dissemination of this product is governed by the Traffic Light Protocol (TLP) marking in the header. For more information about TLP, see <https://us-cert.ssa.gov/tlp/>.

- **CVSS v3 7.5**
- **ATTENTION:** Exploitable remotely/low attack complexity
- **Vendor:** Emerson
- **Equipment:** Rosemount X-STREAM Gas Analyzer
- **Vulnerabilities:** Inadequate Encryption Strength, Unrestricted Upload of File with Dangerous Type, Path Traversal, Use of Persistent Cookies Containing Sensitive Information, Cross-site Scripting, Improper Restriction of Rendered UI Layers or Frames

Successful exploitation of these vulnerabilities could allow an attacker to obtain sensitive information, modify configuration, or affect the availability of the device.

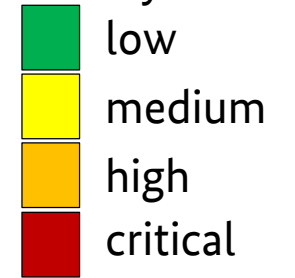
3.1 AFFECTED PRODUCTS

Federal Office
for Information Security

Vulnerability management with CSAF – why SBOM is not enough | Thomas Schmidt Page 18

Manual process

Severity of advisory



Vendor

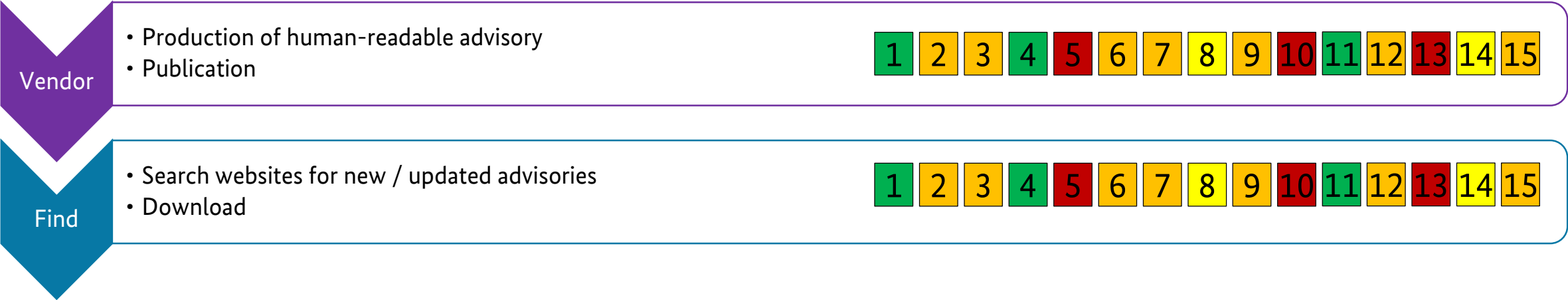
- Production of human-readable advisory
- Publication



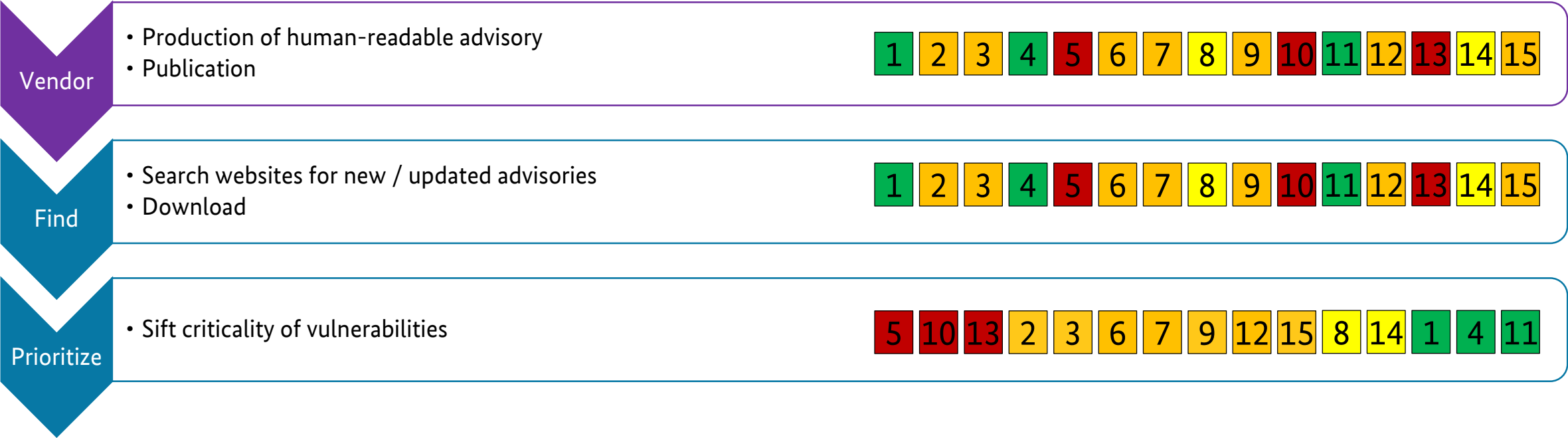
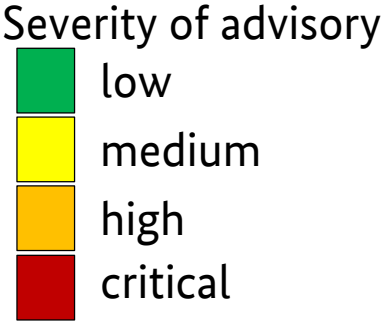
Manual process

Severity of advisory

low
medium
high
critical



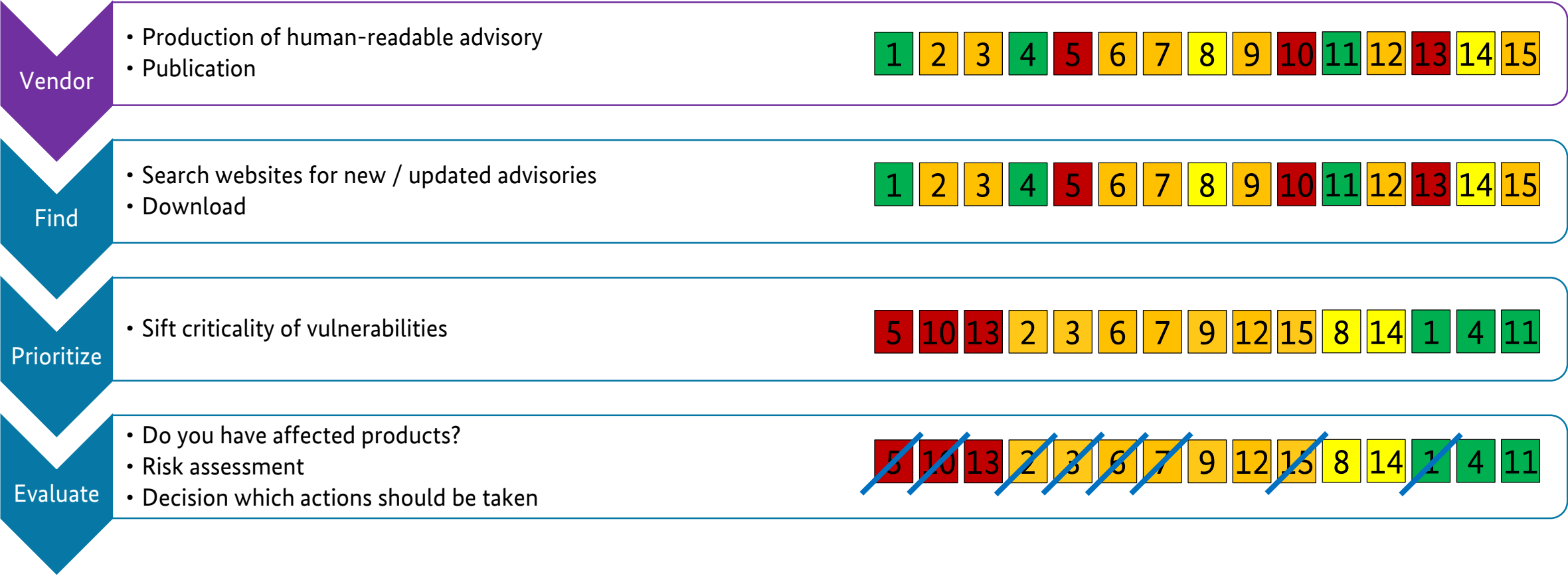
Manual process



Manual process

Severity of advisory

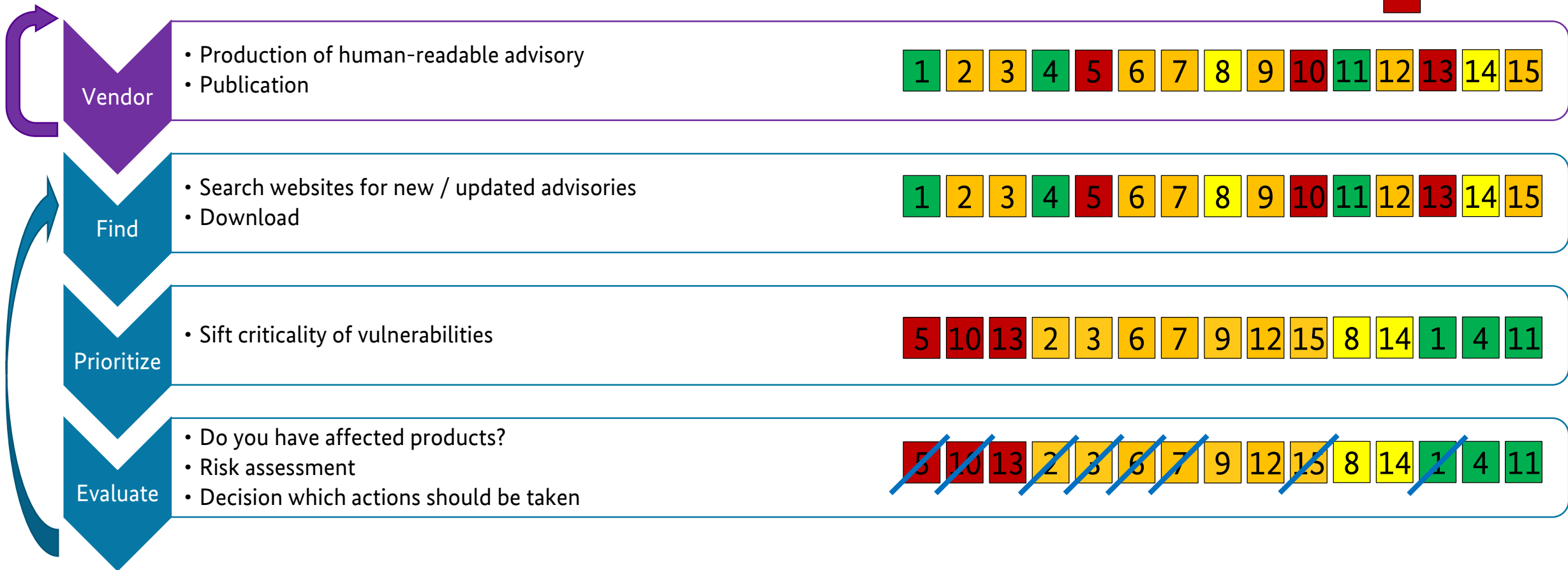
low
medium
high
critical



Manual process

Severity of advisory

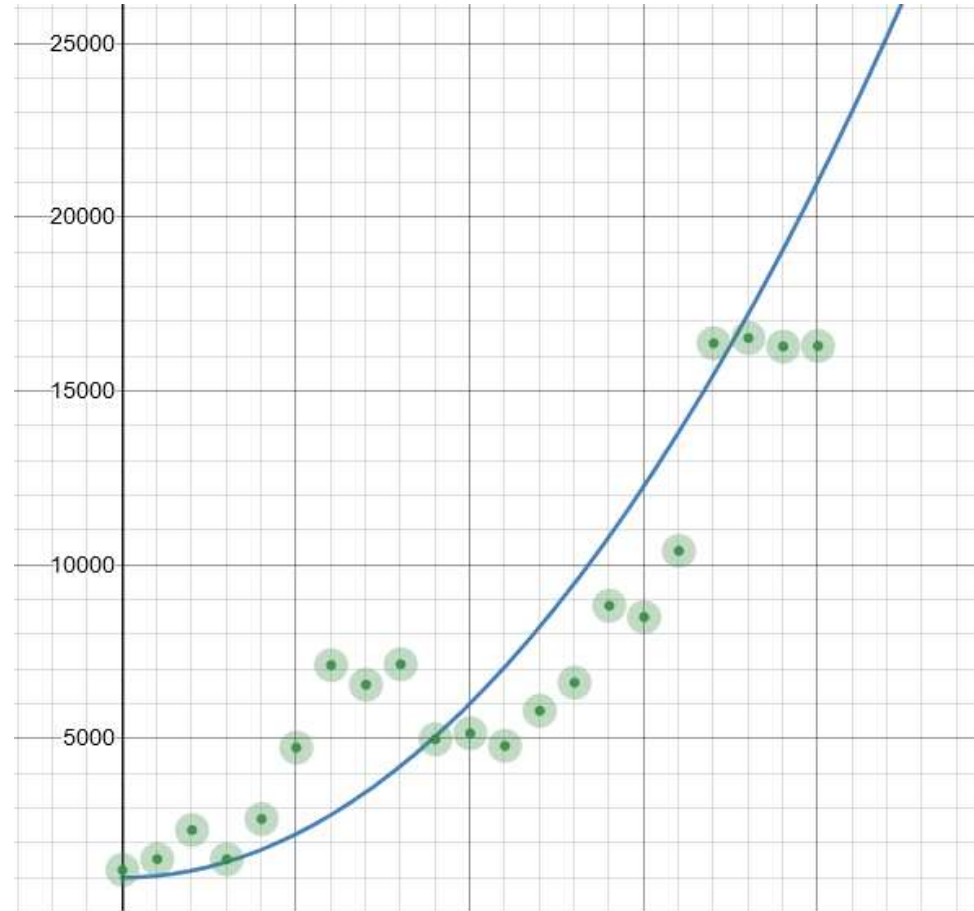
low
medium
high
critical



Number of Advisories



Number of ~~Advisories~~ CVE



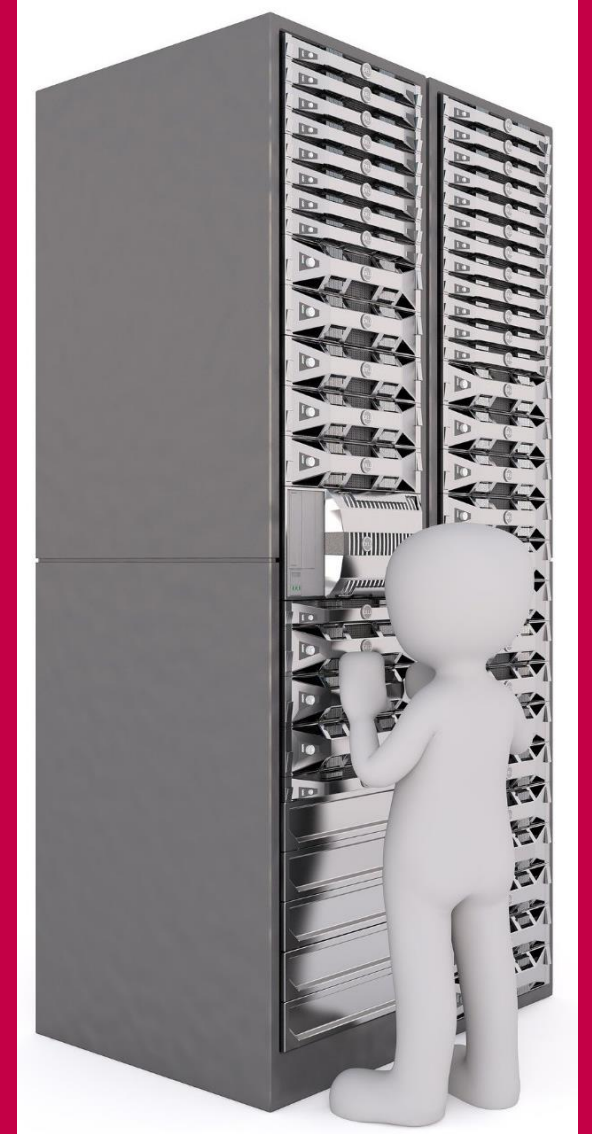
That doesn't scale!



Possible solutions



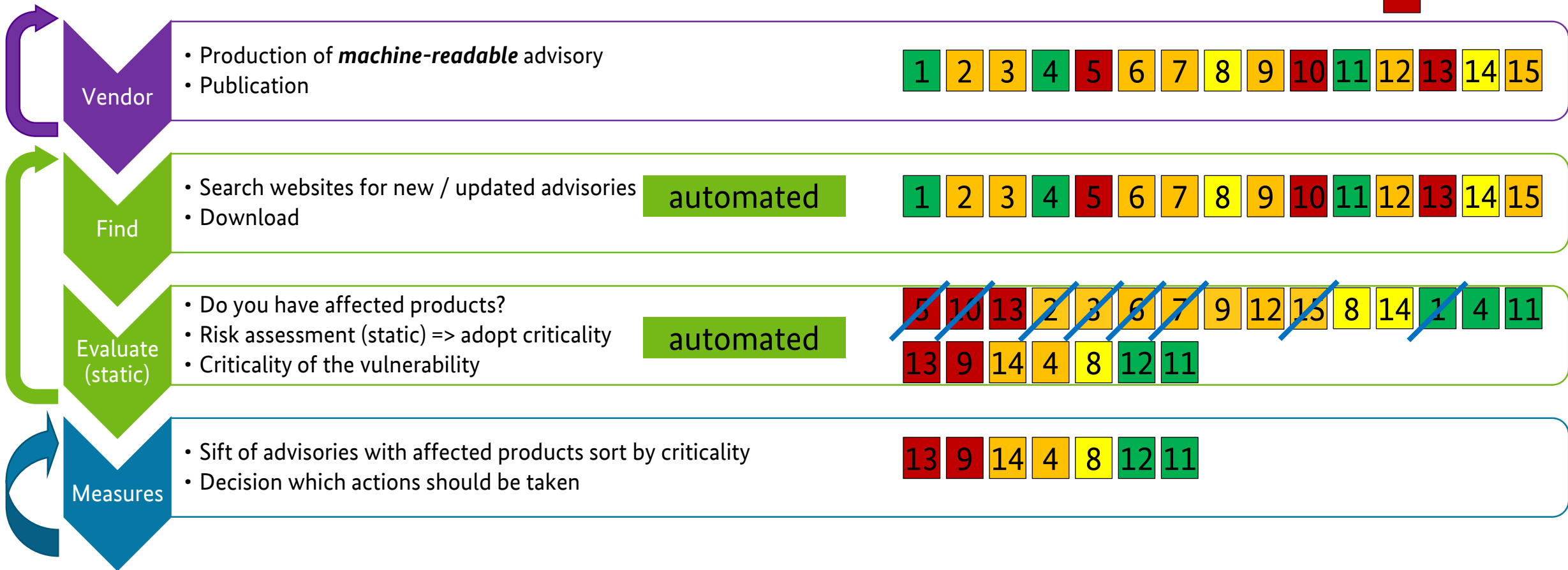
Let's automate the process...



Process with CSAF

Severity of advisory

low
medium
high
critical



What is CSAF?

Common Security Advisory Framework

- International, open and free standard
- Machine-readable format for security advisories (JSON)
- Standardized way of distribution security advisories
- Build with automation in mind
- Standardized tool set
- Guidance to actionable information
- Successor of CSAF CVRF 1.2



Ready to use!

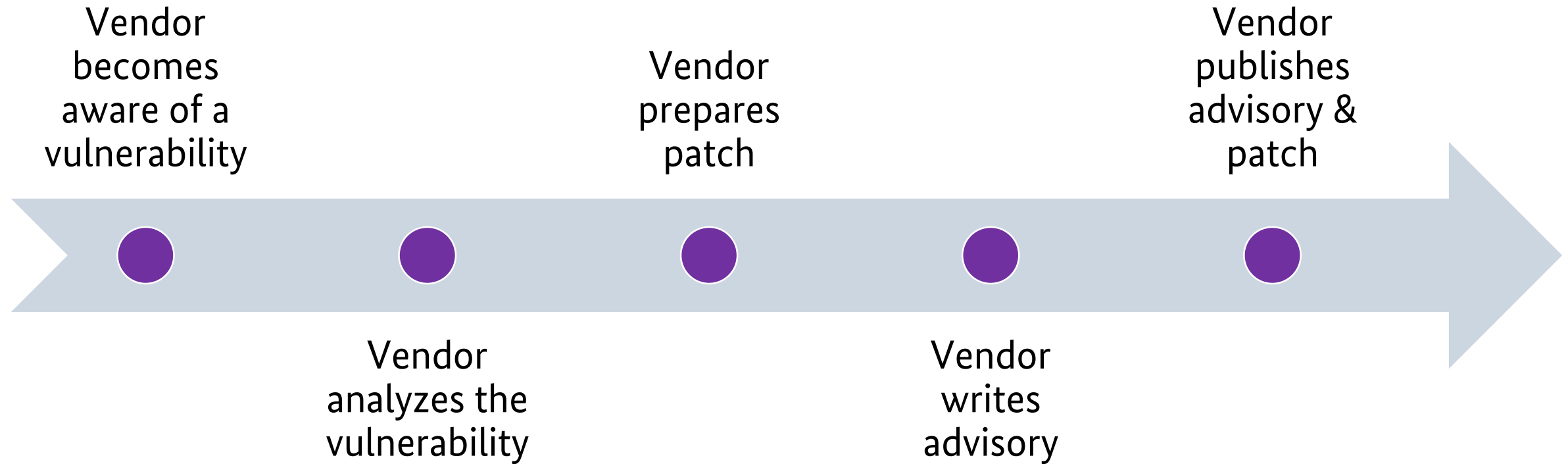
Requirements for asset owners

- Machine-readable asset inventory
- Request Advisories in CSAF from vendors
- Connection between both of them to leverage the full potential

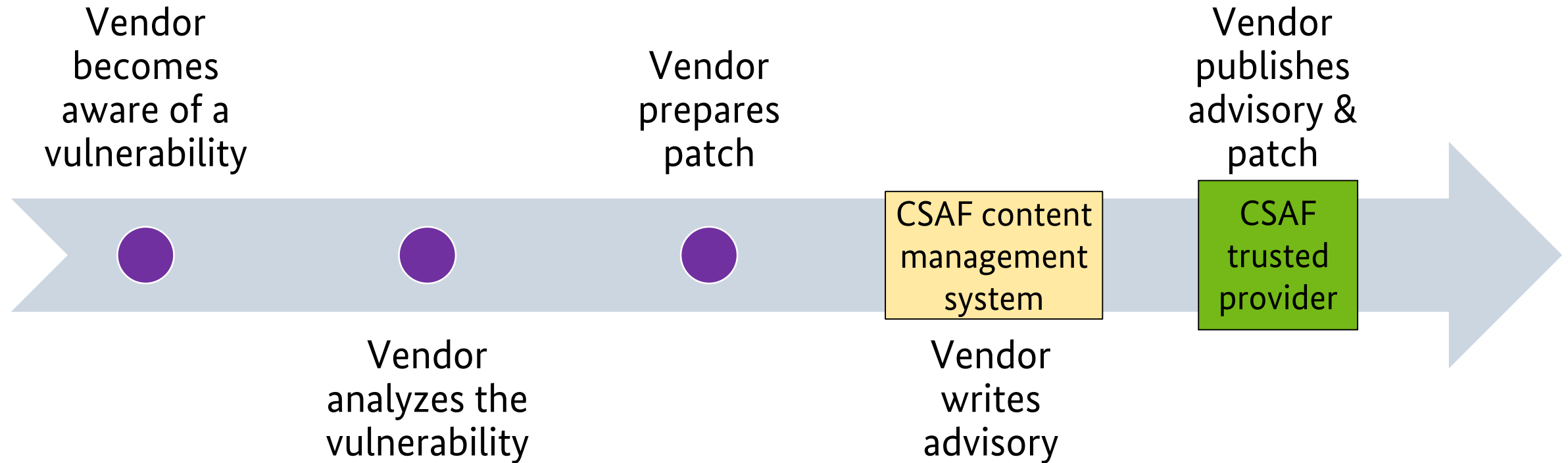


Vendors' Perspective

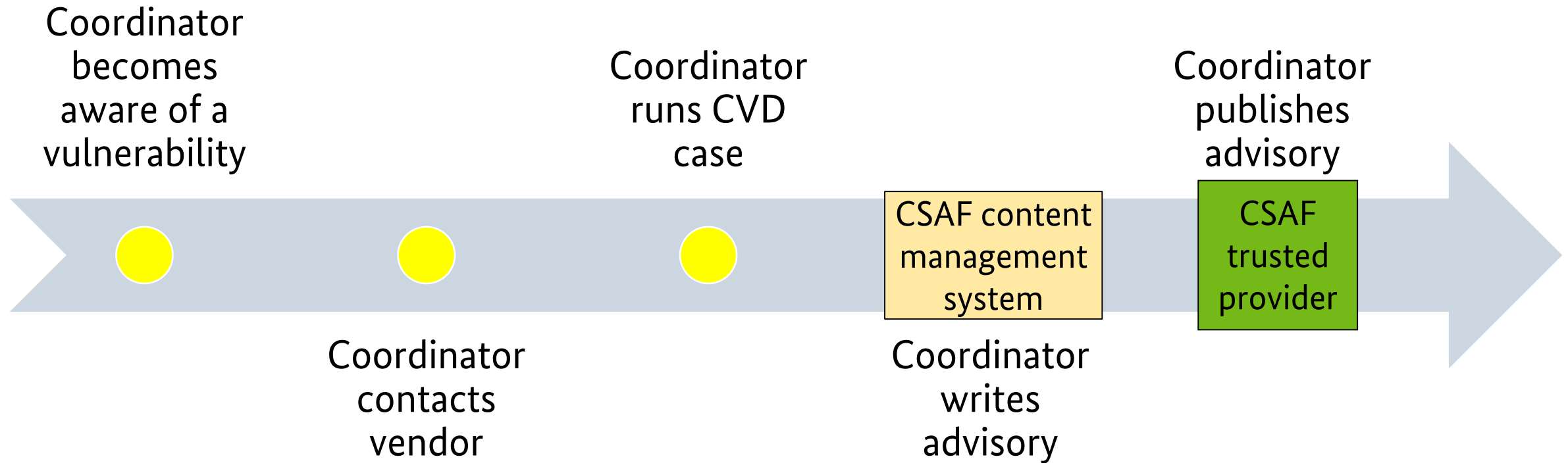
Vendor



Vendor



Coordinator (CVD)



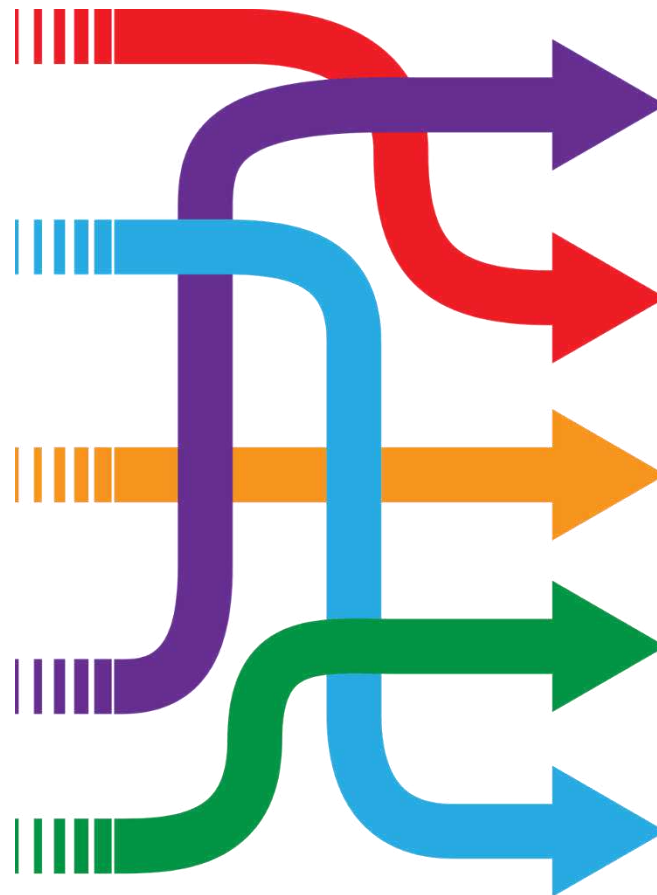
Distribution

Where to find CSAF documents?

✓ Valid CSAF documents ✓ File name restrictions ✓ TLS enforced ✓ TLP:WHITE freely accessible	CSAF publisher
✓ Well-defined URL / security.txt / DNS => provider-metadata.json ✓ List of advisories and latest changes and Fixed folder structure ✓ or ROLIE feeds ✓ Restriction on >=TLP:AMBER ✓ All requirements from CSAF publisher	CSAF provider
✓ Sign own advisories ✓ Hash advisories ✓ Published OpenPGP keys for integrity checks ✓ All requirements from CSAF provider	CSAF trusted provider

<https://docs.oasis-open.org/csaf/csaf/v2.0/csaf-v2.0.html#7-distributing-csaf-documents>

Everything perfect?

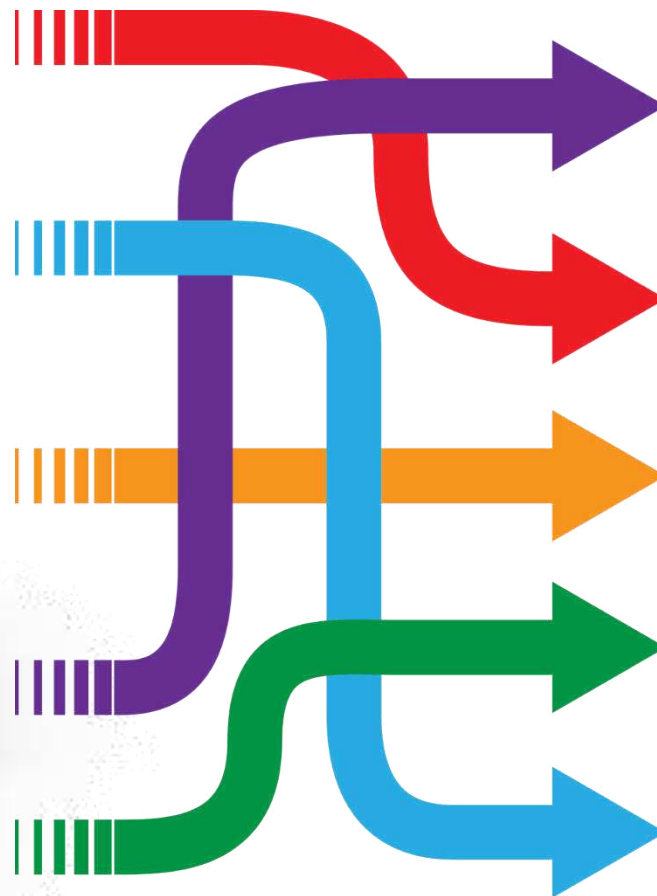


CSAF
publisher

CSAF
provider

CSAF
trusted
provider

Obviously not! Still many sources of information



CSAF publisher	CSAF publisher	CSAF publisher	CSAF provider	CSAF publisher	CSAF provider
CSAF publisher	CSAF publisher	CSAF trusted provider	CSAF publisher	CSAF provider	CSAF publisher
CSAF publisher	CSAF trusted provider	CSAF provider	CSAF provider	CSAF provider	CSAF trusted provider
CSAF trusted provider	CSAF trusted provider	CSAF trusted provider	CSAF provider	CSAF publisher	CSAF publisher
CSAF publisher	CSAF publisher	CSAF publisher	CSAF publisher	CSAF trusted provider	CSAF provider
CSAF trusted provider	CSAF provider	CSAF publisher	CSAF publisher	CSAF publisher	CSAF provider
CSAF trusted provider	CSAF trusted provider	CSAF trusted provider	CSAF trusted provider	CSAF provider	CSAF trusted provider

One more step needed to make it easy ...
Saradi to the rescue!



CSAF aggregator

Scalable and resilient advisory distribution infrastructure (Saradi)

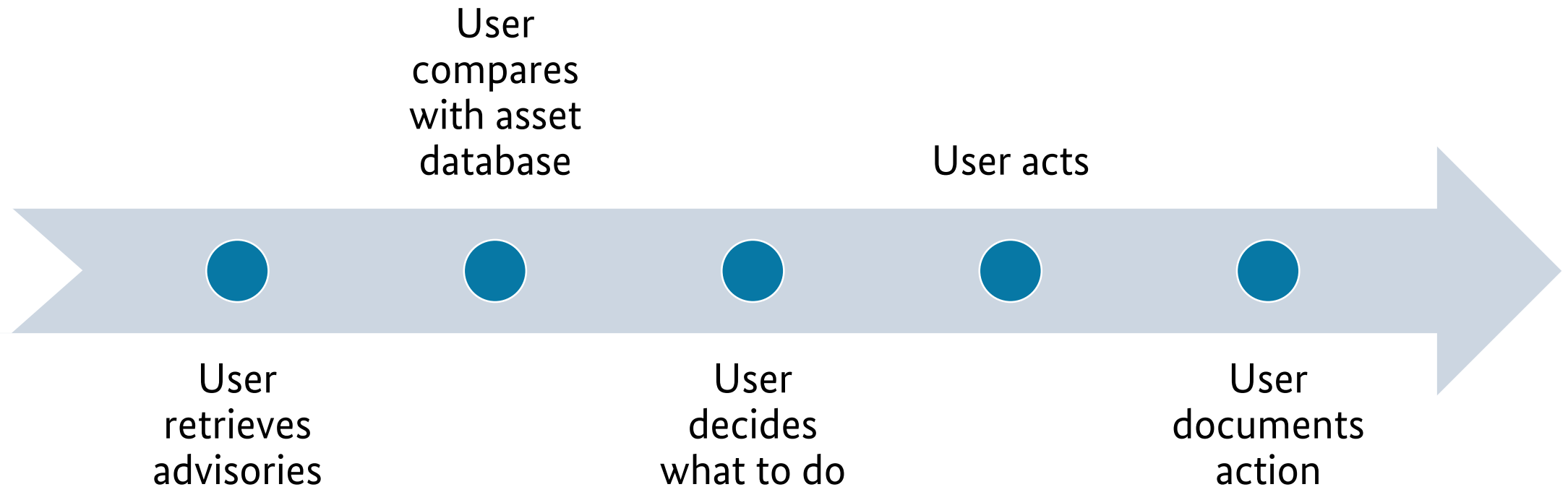
CSAF aggregator

- Trusted party
- Collects advisories from issuers
- Provides them
- API optional
- One-stop-shop
- Multiple around the world (National CERTs)

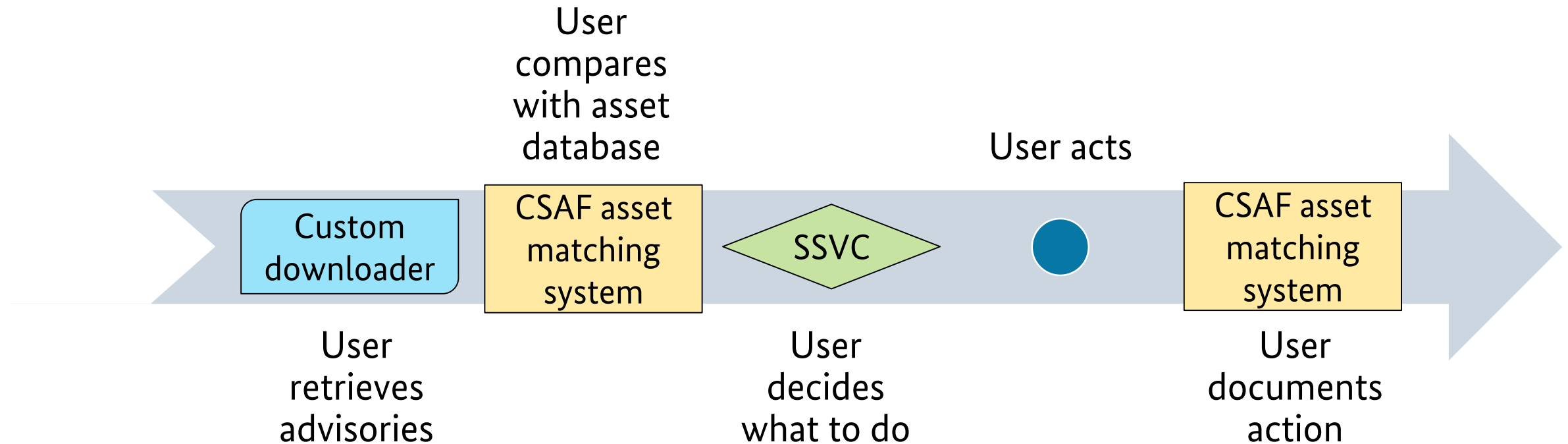


Users' Perspective

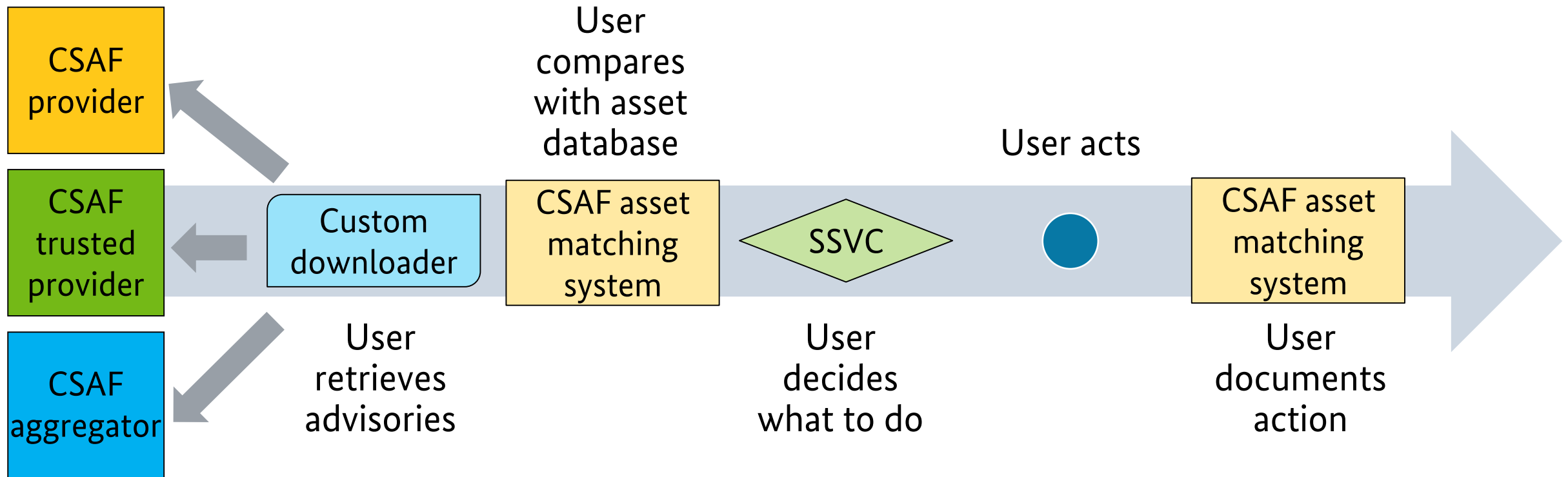
User



User

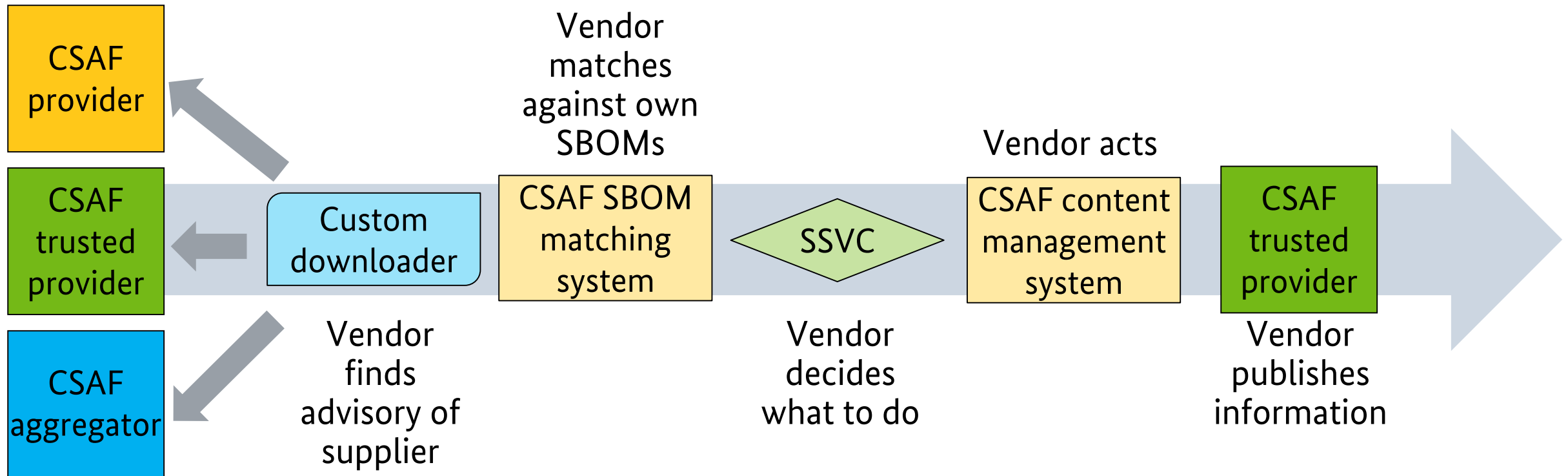


User



Supply chain: vendors' view

Supply chain



Tools developed by the community

- CSAF producer: <https://github.com/secvisogram/secvisogram>
- CSAF content management system: <https://github.com/secvisogram/secvisogram> + <https://github.com/secvisogram/csaf-cms-backend> (WIP)
- CSAF trusted provider: https://github.com/csaf-poc/csaf_distribution
- CSAF aggregator: https://github.com/csaf-poc/csaf_distribution
- Provider checker: https://github.com/csaf-poc/csaf_distribution (WIP)
- CSAF management system: *open for commercial and Open Source tools*
- CSAF asset matching system: *open for commercial and Open Source tools*
- CSAF downloader: https://github.com/csaf-poc/csaf_distribution
- CSAF full validator: <https://github.com/secvisogram/csaf-validator-service>
- **Your tools?**

What about VEX?

VEX

- **Vulnerability Exploitability eXchange**
- Communicate product status explicit
 - Not affected
 - Affected
 - Fixed
 - Under investigation
- Machine-readable to address scalability



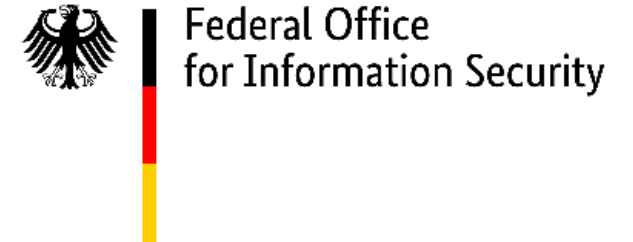
VEX and CSAF

- VEX is a profile in CSAF
- Specific, mandatory fields
- Uses same infrastructure and systems
- VEX is parallel to SBOM (not necessarily in the SBOM)

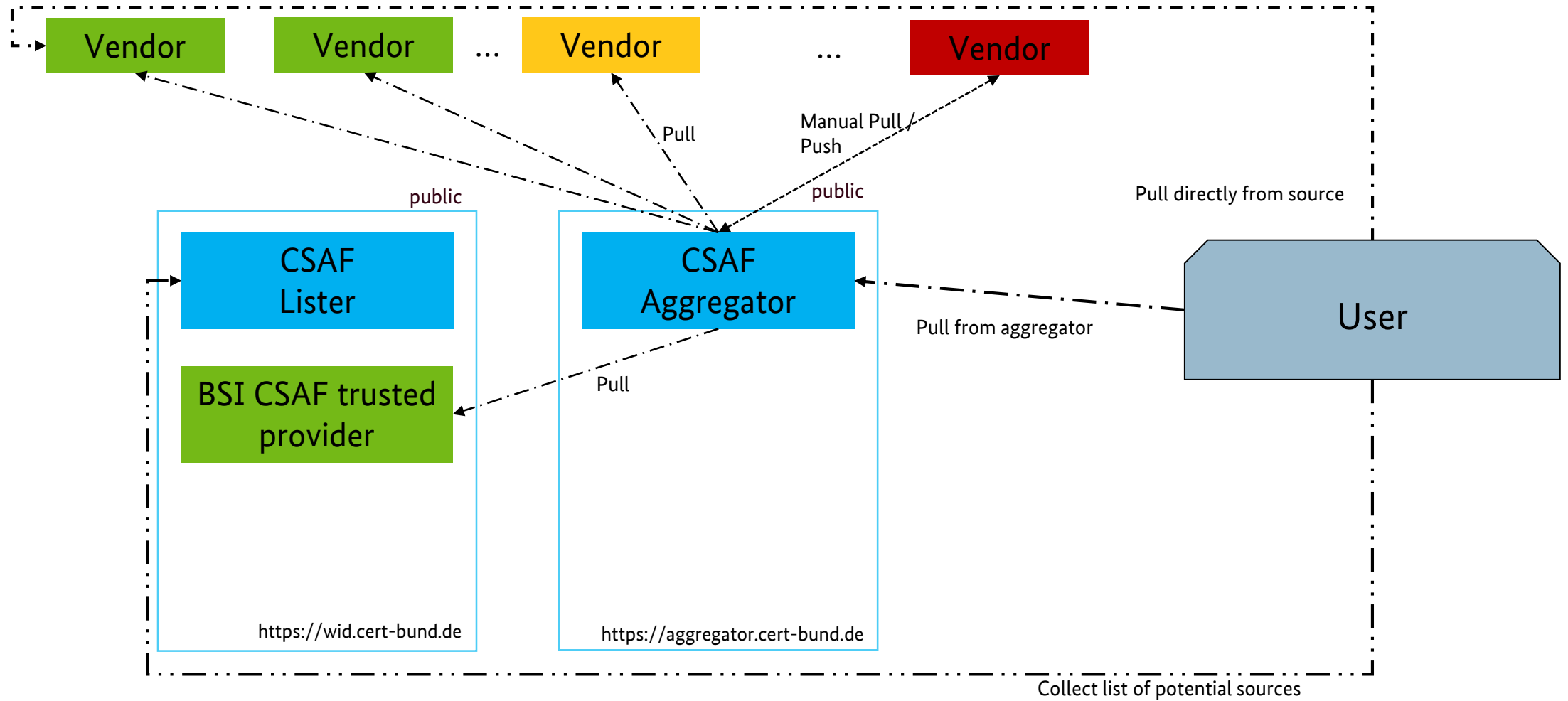


CSAF in Operation

Organizations publishing CSAF

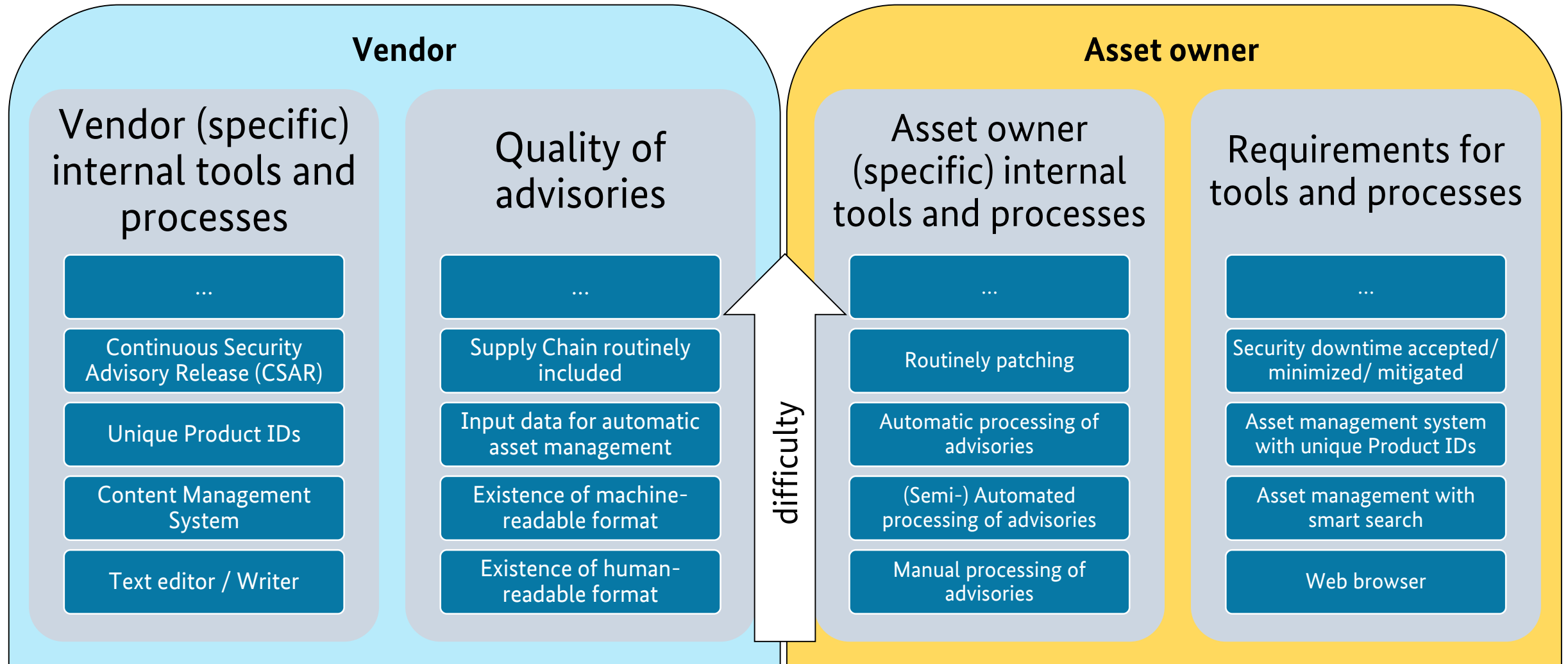


Ecosystem

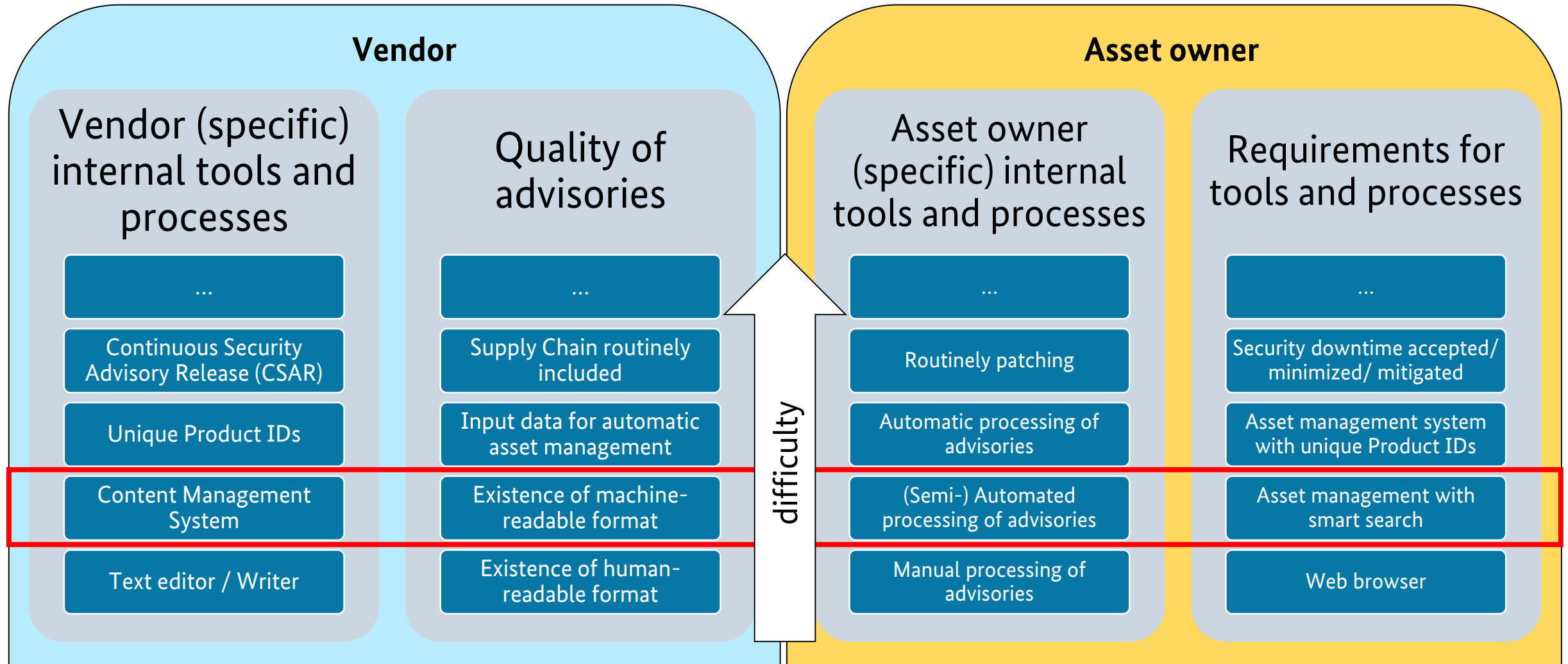


Conclusions

Two sides of the same coin – different maturity stages



Next step: reach stage 2 across parties



Key takeaways & actions

- Number of vulnerabilities discovered is rising
=> number of advisories as well
- Advisories are needed for risk-based decisions
- Automation is possible – so automate the boring stuff
- Request your vendors to provide CSAF 2.0
- Provide CSAF documents to your customers to ease their pain
- Send out VEX as CSAF to use the same tools
- **Spread the word! #oCSAF #advisory**



Where to find more information?

<https://csaf.io>

OASIS TC: CSAF website: https://www.oasis-open.org/committees/tc_home.php?wg_abbrev=csaf

CSAF GitHub: <https://github.com/oasis-tcs/csaf>

CSAF 2.0 JSON Schema: https://docs.oasis-open.org/csaf/csaf/v2.0/csaf_json_schema.json

CSAF 2.0 Prose: <https://docs.oasis-open.org/csaf/csaf/v2.0/csaf-v2.0.html>

CSAF 2.0 Examples: https://github.com/oasis-tcs/csaf/tree/master/csaf_2.0/examples

Secvisogram sources: <https://github.com/secvisogram/secvisogram>

Running Demo: <https://secvisogram.github.io>

Mr. Thomas Schmidt
Subject Matter Expert
Industrial Automation and Control Systems

csaf@bsi.bund.de

Tel. +49 (0) 228 9582 6404

Fax +49 (0) 228 10 9582 6404

Bundesamt für Sicherheit in der Informationstechnik (BSI)

Godesberger Allee 185-189

53175 Bonn

www.bsi.bund.de/dok/en_csaf

